HARRISHEALTH SYSTEM

INFORMATION SECURITY DEPARTMENT

CYBER SECURITY RISK ASSESSMENT:

SYSTEM SECURITY VALIDATION DOCUMENT (SSVD)

Last Updated: July. 22, 2020

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

A.	INFORMATION SYSTEM GENERAL INFORMATION	
	[To be completed by Harris Health Project Manager]	
1.1	**System Name/Version**	PeriWatch Survillance (Watchchild)
	Deployment Type	☒ On-Premise ☐ SaaS ☐ Combination
	System Status	☐ New ☒ Modification to Existing ☐ Upgrade
	Purchase Status	☒ Pre-Acquisition ☐ Post-Acquisition
	Contract Value	Amount in US $ 5,775.00
	Project ID Number	CRN 2880
	Organizational Strategic Goal	Improve process flow
	Installation Location	Harris Health System
	Criticality Level (choose ONE)	☐ Patient Safety ☐ Mission Critical ☒ Essential ☐ Non-Essential
	Estimated Installation Date	
	Required Operational Date	
1.2	**Role**	**Project Manager**
	Name	Swapna D Pillai
	Title	Epic Clinical Sys Analyst III
	Department	HIS Clinical
	Email Address	Swapna.Pillai@harrishealth.org
	Phone Number	346-426-0776
	Role	**Sponsor**
	Name	Suzanne Amanda Lundeen
	Title	Administrative Director of Nursing
	Department	Executive Nursing
	Email Address	Suzanne.Lundeen@harrishealth.org
	Phone Number	713-873-2828
	Role	**Vendor**
	Name	PeriGen
	Title	Technical Services Representative
	Department	Technical Support
	Email Address	Francisco.Savinon@perigen.com
	Phone Number	984-208-7875
	Role	**Data Owner (Director or Above)**
	Name	Suzanne Lundeen
	Title	Administrative Director of Nursing
	Department	Executive Nursing
	Email Address	Suzanne.Lundeen@harrishealth.org
	Phone Number	713-873-2828

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

	Role	Privileged User
	Name	Carolyn Fairchild
	Title	Perinatal Nursing IS Coordinator
	Department	Women's & Infant Service Adm
	Email Address	Carolyn.Fairchild@harrishealth.org
	Phone Number	713-873-2256

1.3 **Define the purpose/scope of the system (high level business objective).**

Create path for Oxytocin documentation flow from MAR to Labor Flow sheet. Current workflow requires double documentation of Oxytocin rates.

1.4 **Is an approved Business Associate Agreement (BAA) on file with the vendor?**

☒ Yes (provide attachment) ☐ No ☐ Pending ☐ Not Applicable (state reason)

Is there an approved Contract on file with the vendor for this project?

☒ Yes (provide attachment) ☐ No ☐ Pending ☐ Not Applicable (state reason)

[To be completed by Vendor or Harris Health Technical Contact]

1.5 **Provide a summary of the system's key components, including a complete listing of software to be installed and intended use or function (e.g. versions, Peripherals, Browsers, APIs etc.).**

PeriWatch Surveillance 2022.1.2, Rhapsody 7.1.1, SQL 2019

Operating System: Windows Server 2019, SQL Server 2019

Database(s):

1.6 **Will this system be used to accept, process, store or transmit:**

ePHI? ☒ YES ☐ NO Data Fields: Exams, Annotations

Is the Vendor/Application HITRUST Certified?

☐ Yes (provide Certificate as an attachment) ☒ No

PII? ☒ YES ☐ NO Data Fields: Patient Name

PCI Data? ☐ YES ☒ NO Data Fields:

If PCI Data is involved, attach current Attestation Of Compliance (AOC)

Other Data:

(Include data fields such as name, address, MRN, SSN, DOB, CC Number, etc.)

MRN, Visit Number, DOB

1.7 **Does vendor have a SOC 2 Type II report? Or a SOC 3 report?**

☐ Yes (attach current report) ☒ No

The system is 100% on-prem.

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

B.	SYSTEM INTERFACE AND INTERCONNECTIONS
1.1	**Provide as an attachment, a system diagram illustrating the logical connectivity and data flows between this system and any other system (e.g. Epic, Middleware, Payment Gateways, POS terminals, scanners, wired/wireless networks, etc.).** Screenshot attached
1.2	**Does the system connect with any other system/network?**(internal or external) ☒ Yes (explain in 1.3 below) ☐ No
1.3	**List the data exchanged between this system and other systems/network.**

System Name	Connection Type (e.g., Wireless, Serial , Ethernet)	Data Exchanged (e.g HL7, DICOM, CHD)
EMR	Ethernet	HL7

1.4	**How is electronic data-in-transit protected?** (Encryption methods, VPN, TLS, etc.) Data viewed from a workstation is all transmitted via HTTPS over TLS. All data sent from EMR is via HL7 interface
1.5	**List the services and protocols required for electronic communication. Indicate whether internal or external to the HCHD network. Include source, destination, protocol, and port number required.**

Internal/ External	Service	Source	Destination	Protocol	Port
Internal	Interface	EMR	PWS Interface	HL7	17676, 17677, 176

C.	FACILITY ACCESS CONTROLS
1.1	**Provide procedures for controlling physical access to the facility housing the system. Include personnel access controls, after-hours access, etc.**

D.	DATA STORAGE
1.1	**Provide a list of the types of removable and non-removable data storage media and discuss its purpose.** All data is saved on the SQL DB
1.2	**Describe where data is stored and how it is secured; include integrity mechanisms and colocation with other data.** All data is saved on the SQL DB. SQL TDE is an option for encrypting the stored data.
1.3	**Provide as attachment the procedures for backup and restoration of data.** Client is responsible for backup and restore procedures.

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

1.4	**Describe the physical and technical protection of the backup hardware, software, and firmware.** N/A
E.	**USER ACCESS AND OPERATION**
1.1	**Does the application support integration with the enterprise identity management system?** (e.g., LDAP, Kerberos, Directory Services, etc.) ☒ Yes (Indicate supported technology below and **skip to question 1.7**) Supported Technologies: LDAP/LDAPS ☐ No (**answer questions 1.2-1.6**)
1.2	**Is user authentication controlled by means other than user account and password or PIN?** (e.g. certificates, token, biometric, etc.) ☐ Yes (indicate what other mechanisms are used below) Other mechanisms: ☒ No
1.3	**Check all boxes that apply to the passwords assigned to the system users.** ☒ All users have their own unique userid and unique password ☐ Some users share a userid and password (Explain) Cannot validate password as that is stored in AD but all users ☐ Some users share a password (Explain) ☐ New users are forced to change their passwords upon first login ☐ Passwords are generated by the user ☐ Passwords generated by the user are validated with automated tools ☐ Users are required to use strong passwords generated by the system ☐ Passwords are generated by a system (Specify software and provide details) ☐ Passwords are provided by an access control manager ☐ Users can change their passwords whenever the user feels it is necessary ☐ Passwords must be at least 8 characters in length and contain at least 3 of 4 of the following character types: upper-case, lower-case, number, and special character (@, #, $, %,).
1.4	**Are users forced to change their password on a timely basis?** ☐ Yes (indicate timeframe) ☒ No Password policy maintained by AD/GP
1.5	**Can the system prevent users from reusing a password?** ☒ Yes (indicate how many passwords are remembered): Password policy maintained by

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

	☐ No
1.6	**Is password transmission and storage encrypted and unviewable, even to system administrators?** ☐ Yes ☒ No
1.7	**Can the system be set to automatically lock a user's account after a predetermined number of consecutive unsuccessful logon attempts?** ☐ Yes (Indicate number of attempts allowed): ☒ No
1.8	**If a user's account is locked out, who is authorized to reinstate the user's account (check all that apply)?** ☐ System Admin ☒ Active Directory Administrator ☐ Privileged User ☐ System Owner ☐ Any system user ☐ Self-service password reset ☐ Other:
1.9	**Does the system prohibit users from logging into the application on more than one workstation at the same time with the same user ID?** ☐ Yes ☒ No
1.10	**Can the system be set to automatically lock or log a user off the system after a predefined period of inactivity?** ☒ Yes (Indicate timeframe): Default is 10 minutes but can be adjusted ☐ No
1.11	**Can access be defined based upon the user's job role? (Role-based Access Controls (RBAC))?** ☒ Yes ☐ No
1.12	**Provide as attachment a list and description of user roles.** User Roles are determined when engaging the client. Roles can be dynamically created. Typicall set up includes roles for Administrators, Providers, Clinicians and ViewOnly
1.13	**Can the system support the removal of a user's access privileges without requiring deletion of the user account?** ☒ Yes ☐ No
1.14	**Does the system support a mechanism for allowing emergency access by a caregiver to a patient's electronic health information that is not included within their standard access privileges?** ☐ Yes ☒ No ☐ Not Applicable:
1.15	**If yes, does the application capture and retain details pertaining to this action for review?** ☐ Yes ☐ No
1.16	**If yes, do the caregiver's access privileges revert back to the original setting upon next log-in?** ☐ Yes ☐ No

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

F.	PRIVILEGED USER ACCESS AND OPERATION
1.1	**Will all privileged users have their own unique userid and password?** ☒ Yes (Explain): All accounts will be managed in AD, we cannot ☐ No
1.2	**Can non-privileged users change the configuration of the system and/or the content of any files other than data files?** ☐ Yes (Explain): ☒ No
1.3	**Can non-privileged users set the system access rights for other users?** ☐ Yes (Explain): ☒ No
1.4	**Provide any guides or manuals for the system's privileged user.** Attached

G.	AUDIT CAPABILITIES
1.1	**Is audit log tracking a feature available in the current version of this software application?** ☒ Yes ☐ No **(Skip to section H.)**
1.2	**Does the system provide unique identification of each user and association of that identity with all auditable actions taken by that individual?** ☒ Yes ☐ No
1.3	**Do non-privileged users have the following access to audit log files (check all that apply)?** ☐ View ☐ Modify ☐ Delete ☒ No access to audit log files
1.4	**Check the boxes corresponding to the information captured in audits:**

☒ Userid	☒ Type of event or action	☒ Success of the event
☒ Time	☒ Workstation ID	☒ Failure of the event
☒ Date	☐ Resources	☐ Remote Access
☐ Other:	☐ Other:	☐ Other:

1.5 **Check the boxes corresponding to the types of activities audited.**

Event Description	Do you audit SUCCESS	Do you audit FAILURE	Event Description	Do you audit SUCCESS	Do you audit FAILURE
Logins	☒	☒	Logoffs	☒	☒
Printing	☒	☒	Copying data to removable media	☐	☐
Use of privileged user or root privileges	☒	☐	All access (including inquiry, which is required by HIPAA) to	☒	☐

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

				patient information		
	Attempts to change data	☒	☒	Deletion of a directory, file, or data element(s)	☐	☐
	Creation, modification, and deletion of user accounts	☒	☒	Remote support connection attempts	☐	☐
	Remote support activities	☒	☒	Other	☐	☐

1.6	**Can the audit log data be exported from the system for further processing** (e.g. SIEM, storage, analysis)**?** ☒ Yes ☐ No
1.7	**Indicate the location(s) where the audit logs will be stored.** Audit logs are stored on the SQL DB.
1.8	**Indicate how audit log files are protected from unauthorized alteration:** SQL access control
1.9	**How long is the audit log maintained on-line?** No limit.
1.10	**How long is the audit log maintained off-line?** Log are always online in the DB.
1.11	**Does the system allow a system administrator to include/exclude audited events based on organizational policy and operating requirements or limits?** ☐ Yes ☒ No
1.12	**Can the system continue normal operation even when security audit capability is non-functional?** (e.g., if the audit log reaches capacity, the application continues to operate) ☒ Yes ☐ No
H.	**SECURITY OF REMOTE ACCESS AND CONTROLS**
1.1	**Will remote access be required for any reason?** ☒ Yes **(Continue below)** ☐ No **(Skip to Section I)**

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

1.2	**Can vendor support any of the following approved methods remote support/maintenance?** ☒ Citrix connection ☒ Cisco VPN Client ☐ Cisco Business-to-Business VPN using IPSec ☒ Cisco WebEx ☒ Other (specify) SecureLink is presently used.
1.3	**Does the system associate remote support activities with an individual employee of the vendor?** ☐ Yes ☒ No
1.4	**What Multifactor Authentication method is used/supported for remote access?** ☒ DUO ☐ Imprivata ☒ Other (specify) Microsoft Authenticator
I.	**PROTECTION FROM MALICIOUS CODE**
1.1	**Is the system compatible with commercial off the shelf (COTS) virus scanning software products for removal and prevention from malicious code?** ☒ Yes ☐ No
1.2	**Does the system's client software operate without requiring the user to have local administrator level rights in order to run the application?** ☒ Yes ☐ No
1.3	**Can the operating system hosting the application be updated by the user without voiding the application warranty or support agreement?** ☒ Yes ☐ No (explain how operating system updates/patches are provided). Updates/patches can be installed according to company policy. Major OS version changes will need to coordinated with PeriGen.
J	**VULNERABILITY & PATCH MANAGEMENT**
1.1	**Do you scan your IT assets (applications, servers, network devices, websites etc.) for vulnerabilities? If so, how frequently?** ☒ Yes (Explain) ☐ No (Explain) Regularly scanned with the Veracode platform (both static and synamic scans)
1.2	**Do you remediate identified vulnerabilities within 30 days?** ☒ Yes (Explain How) ☐ No (Explain) Critical, Very high and high vulnerabilities are immediately fixed prior to release of any new version. All other are corrected on the product maintenance release schedule.
1.3	**Do you have a formal patch management process that covers aspects such as testing prior to implementation, criticality based patching cycle, etc.?** ☒ Yes (Explain How) ☐ No (Explain) Any new patch is communicated to the customer. If/When they choose to take the version, it is

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

1.4	**Do you have formal change control process that covers patching and configuration changes?** ☒ Yes (Explain) ☐ No (Explain why) Product change control is past of the PeriGen SDLC process. Application configuration changes are only done on customer request. Those are captured in Device History Records and hopefully by customer stakeholders as well.
1.5	**Do you subscribe to any external threat intelligence or security-alert monitoring services?** ☐ Yes (Explain) ☒ No (Explain why)
1.6	**Do you have a documented process to trigger investigation and alert your customers in the event of a suspected data breach or security event that may impact customers?** ☐ Yes (Explain) ☒ No (Explain) The system is running 100% on-prem on the customer network on customer provided and mai
1.7	**Do you test the security of your product before each customer-release?** ☒ Yes (Explain) ☐ No (Explain) Internal QA process and Veracode scanning.
K	**MEDICAL DEVICES**
1.1	**Do you comply with regulatory guidance for pre- and post-market management of cybersecurity in medical devices for the customer's jurisdiction?** ☒ Yes (Explain) ☐ No (Explain) ☐ N/A PeriGen complies with ISO 13485, 14971, 15223, 20417 which are more specific guidelines f
1.2	**Do you have a documented process to inform customers of the presence of any exploitable security vulnerability which presents risk to patient health or materially impacts the expected function of the acquired device immediately upon becoming aware of such a vulnerability?** ☒ Yes (Explain) ☐ No (Explain) ☐ N/A Email communication to the identified system owner.
L	**CLIENT SECURITY CONTROLS**
1.1	**Can the system's client software function properly on a workstation utilizing full disk encryption?** ☒ Yes ☐ No

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc

284218 | 08.2020

1.2	**Can the system's client software function properly on a workstation utilizing removable media controls (Checkpoint Media Encryption)?** ☒ Yes ☐ No

Printed versions of this document are uncontrolled. Please go to the Harris Health Document Control Center to retrieve an official controlled version of the document. https://apps.hchd.local/sites/dcc